

Statement of Applicability — ISO 27001:2022 SoA v1.0

ISO 27001:2022 — Vendor Management Gap Assessment · International standard ISO/IEC 27001:2022

Status: DRAFT

Generated: 2026-06-29

Ref	Control / Requirement	Description	Applicable?	Result	Justification	Applied Controls
4.1	Understanding the organization and its context	Identify internal and external factors that influence the organization's ability to achieve information security objectives, ensuring the ISMS is aligned with its context.	✓ Yes	Not assessed		—
4.2	Understanding the needs and expectations of interested parties	Analyze the needs and expectations of interested parties to incorporate them into the ISMS and address relevant information security requirements.	✓ Yes	Not assessed		—
4.3	Determining the scope of the information security management system	Define the scope of the ISMS by considering internal and external factors, stakeholder needs, and dependencies within the operational environment.	✓ Yes	Not assessed		—
4.4	Information security management system	Build, run, and continually improve an ISMS to effectively manage information security risks and meet organizational goals.	✓ Yes	Not assessed		—
5.1	Leadership and commitment	Demonstrate leadership and commitment by supporting the ISMS, aligning it with organizational objectives, allocating resources, promoting a security culture, and driving continual improvement.	✓ Yes	Not assessed		—
5.2	Policy	Establish an information security policy aligned with the organization's objectives and strategic direction, outlining commitments to compliance, continual improvement, and the promotion of informati...	✓ Yes	Not assessed		—
5.3	Organizational roles, responsibilities and authorities	Define, assign, and communicate roles, responsibilities, and authorities to ensure the effective implementation and operation of the ISMS, with accountability aligned to organizational objectives.	✓ Yes	Not assessed		—
6.1.1	General	Establish a process to identify information security risks and opportunities, considering internal and external factors, stakeholder needs, and applicable requirements to ensure the ISMS achieves its...	✓ Yes	Not assessed		—
6.1.2	Information security risk assessment requirement	Establish a process to assess information security risks at planned intervals, using defined criteria to evaluate threats to confidentiality, integrity, and availability, ensuring consistent and reli...	✓ Yes	Not assessed		—
6.1.3	Information security risk treatment	Define a process to address identified information security risks by selecting appropriate controls, ensuring alignment with risk acceptance criteria, and documenting them in a risk treatment plan.	✓ Yes	Not assessed		—
6.2	Information security objectives and planning to achieve them	Set measurable information security objectives aligned with the ISMS and strategic goals, and plan actions detailing responsibilities, resources, timelines, and evaluation methods to achieve them.	✓ Yes	Not assessed		—
6.3	Planning for changes	Plan changes to the ISMS systematically to ensure alignment with information security requirements, seamless integration into existing processes, and effective risk management.	✓ Yes	Not assessed		—
7.1	Resources	Provide the necessary resources to build, run, and continually improve the ISMS, ensuring its effective operation and alignment with organizational goals.	✓ Yes	Not assessed		—
7.2	Competence	Ensure personnel involved in the ISMS possess the necessary competence through appropriate education, training, or experience to fulfill their responsibilities effectively.	✓ Yes	Not assessed		—
7.3	Awareness	Promote awareness among relevant personnel about the ISMS, their role in information security, and the importance of compliance with security policies and requirements.	✓ Yes	Not assessed		—
7.4	Communication	Establish effective internal and external communication processes, ensuring the timely and appropriate exchange of information relevant to the ISMS and its objectives.	✓ Yes	Not assessed		—
7.5.1	General	Document the ISMS as needed to ensure effective planning, operation, control of processes, and alignment with organizational requirements.	✓ Yes	Not assessed		—
7.5.2	Creating and Updating documented information	Ensure ISMS documentation is appropriately created, updated, and controlled, including proper approval and version management.	✓ Yes	Not assessed		—
7.5.3	Control of documented information	Make ISMS documentation accessible and usable for those who need it, while protecting it from unauthorized access or loss.	✓ Yes	Not assessed		—
8.1	Operational planning and control	Plan and control ISMS processes, ensuring consistency with requirements and making necessary adjustments to address risks and opportunities.	✓ Yes	Not assessed		—
8.2	Information security risk assessment	Implement the risk assessment process to identify, evaluate, and prioritize information security risks as defined in the ISMS framework.	✓ Yes	Not assessed		—
8.3	Information security risk treatment	Apply the risk treatment process by selecting and implementing appropriate controls to address identified risks, ensuring alignment with the organization's risk acceptance criteria.	✓ Yes	Not assessed		—
9.1	Monitoring, measurement, analysis, evaluation	Monitor, measure, analyze, and evaluate the ISMS's performance and effectiveness using appropriate methods aligned with the organization's objectives.	✓ Yes	Not assessed		—
9.2.1	General	Conduct internal audits at planned intervals to ensure the ISMS complies with ISO/IEC 27001 requirements and is effectively implemented and maintained.	✓ Yes	Not assessed		—
9.2.2	Internal audit programme	Plan and perform internal audits, including defining criteria, scope, methods, and responsibilities, and report the results to relevant management.	✓ Yes	Not assessed		—
9.3.1	General	Review the ISMS periodically to ensure its suitability, adequacy, and effectiveness in achieving organizational objectives.	✓ Yes	Not assessed		—
9.3.2	Management review inputs	Include inputs such as audit results, ISMS performance, risk status, improvement opportunities, and required changes in the management review.	✓ Yes	Not assessed		—
9.3.3	Management review results	Document the results of the management reviews, including decisions on improvements, ISMS changes, and resource requirements.	✓ Yes	Not assessed		—
10.1	Continual improvement	Identify and act on opportunities for continual improvement to enhance the ISMS's effectiveness and alignment with organizational goals.	✓ Yes	Not assessed		—
10.2	Nonconformity and corrective action	Address nonconformities by taking corrective actions, identifying root causes, and implementing measures to prevent recurrence while documenting the process.	✓ Yes	Not assessed		—

Ref	Control / Requirement	Description	Applicable?	Result	Justification	Applied Controls
A.5.1	Policies for information security	This control establishes and maintains information security policies aligned with organizational objectives. Measures include defining scope, setting goals, and ensuring alignment with compliance req...	✓ Yes	Not assessed		—
A.5.2	Information security roles and responsibilities	This control defines and assigns roles and responsibilities for information security to ensure accountability. Measures include clear documentation of responsibilities, periodic reviews, and enforcem...	✓ Yes	Not assessed		—
A.5.3	Segregation of duties	This control ensures segregation of duties to reduce the risk of errors, fraud, and unauthorized access. Measures include role separation, access restrictions, and regular audits.	✓ Yes	Not assessed		—
A.5.4	Management responsibilities	This control ensures management responsibilities for information security are clearly defined and implemented. Measures include setting objectives, allocating resources, and overseeing compliance.	✗ No	Not applicable		—
A.5.5	Contact with authorities	This control ensures timely communication with relevant authorities during information security incidents. Measures include establishing contact protocols, maintaining updated contact lists, and assi...	✓ Yes	Not assessed		—
A.5.6	Contact with special interest groups	This control facilitates contact with special interest groups to stay informed about security trends and practices. Measures include participation in forums, memberships, and collaborative initiative...	✓ Yes	Not assessed		—
A.5.7	Threat intelligence	This control ensures threat intelligence is developed and maintained to identify and mitigate security risks. Measures include monitoring threat feeds, analyzing trends, and sharing actionable insigh...	✓ Yes	Not assessed		—
A.5.8	Information security in project management	This control incorporates information security into project management practices. Measures include risk assessments, compliance reviews, and security checkpoints during project lifecycles.	✓ Yes	Not assessed		—
A.5.9	Inventory of information and other associated assets	This control ensures an accurate inventory of information and associated assets is maintained. Measures include asset tracking, periodic audits, and classification by sensitivity.	✓ Yes	Not assessed		—
A.5.10	Acceptable use of information and other associated assets	This control defines acceptable use of information and associated assets to ensure proper handling. Measures include documented policies, user training, and enforcement mechanisms.	✓ Yes	Not assessed		—
A.5.11	Return of assets	This control ensures the secure return of assets when employees or contractors leave or change roles. Measures include checklists, asset tracking, and decommissioning protocols.	✓ Yes	Not assessed		—
A.5.12	Classification of information	This control ensures information is classified based on its sensitivity and value to ensure appropriate protection. Measures include classification schemes, access restrictions, and labeling guidelin...	✓ Yes	Not assessed		—
A.5.13	Labelling of information	This control ensures consistent labeling of information to reflect its classification and handling requirements. Measures include standardized templates, training, and audits.	✓ Yes	Not assessed		—
A.5.14	Information transfer	This control establishes secure processes for transferring information between systems or organizations. Measures include encryption, access controls, and secure transfer protocols.	✓ Yes	Not assessed		—
A.5.15	Access control	This control implements and maintains access control mechanisms to restrict access to authorized individuals. Measures include role-based access, multi-factor authentication, and periodic reviews.	✓ Yes	Not assessed		—
A.5.16	Identity management	This control ensures identities are managed securely to guarantee accurate and reliable access to systems. Measures include identity verification, lifecycle management, and access provisioning.	✓ Yes	Not assessed		—
A.5.17	Authentication information	This control protects authentication information, such as passwords, to prevent unauthorized access. Measures include encryption, secure storage, and periodic password updates.	✓ Yes	Not assessed		—
A.5.18	Access rights	This control ensures access rights are regularly reviewed and managed to align with roles and responsibilities. Measures include periodic audits, access revocation, and automated access management.	✓ Yes	Not assessed		—
A.5.19	Information security in supplier relationships	This control ensures information security is embedded in supplier relationships and processes. Measures include due diligence, security reviews, and ongoing monitoring.	✓ Yes	Non-compliant		—
A.5.20	Addressing information security within supplier agreements	This control addresses information security requirements within supplier agreements. Measures include explicit contract clauses, compliance audits, and defined penalties for violations.	✓ Yes	Partially compliant		—
A.5.21	Managing information security in the ICT supply chain	This control manages information security risks in the ICT supply chain to ensure security of services and components. Measures include risk assessments, supplier evaluations, and incident response p...	✓ Yes	Partially compliant		—
A.5.22	Monitor, review and change management of supplier services	This control ensures supplier services are monitored, reviewed, and adjusted to maintain information security. Measures include service level agreements, periodic reviews, and contract updates.	✓ Yes	Non-compliant		—
A.5.23	Information security for use of cloud services	This control ensures the secure use of cloud services by addressing associated risks. Measures include data encryption, access controls, and provider compliance reviews.	✓ Yes	Not assessed		—
A.5.24	Information security incident management planning and preparation	This control ensures proper planning and preparation for managing information security incidents. Measures include incident response plans, training exercises, and communication protocols.	✓ Yes	Not assessed		—
A.5.25	Assessment and decision on information security events	This control establishes processes for assessing and deciding on actions related to information security events. Measures include root cause analysis, risk evaluation, and mitigation plans.	✓ Yes	Not assessed		—
A.5.26	Response to information security incidents	This control ensures effective response to information security incidents to minimize impact and recover quickly. Measures include incident reporting, escalation protocols, and containment strategies.	✓ Yes	Not assessed		—
A.5.27	Learning from information security incidents	This control ensures lessons learned from information security incidents are documented and implemented to improve processes. Measures include post-incident reviews, action plans, and policy updates.	✓ Yes	Not assessed		—
A.5.28	Collection of evidence	This control ensures evidence is collected and preserved during security incidents to support investigations. Measures include chain-of-custody procedures, secure storage, and access controls.	✓ Yes	Not assessed		—
A.5.29	Information security during disruption		✓ Yes	Not assessed		—

Ref	Control / Requirement	Description	Applicable?	Result	Justification	Applied Controls
		This control ensures information security is maintained during disruptions to guarantee continuity of operations. Measures include contingency plans, backup systems, and failover mechanisms.				
A.5.30	ICT readiness for business continuity	This control ensures ICT readiness for business continuity to minimize downtime during disruptions. Measures include testing recovery plans, redundant systems, and disaster recovery sites.	✓ Yes	Not assessed		—
A.5.31	Legal, statutory, regulatory and contractual requirements	This control ensures compliance with legal, statutory, regulatory, and contractual information security requirements. Measures include policy reviews, audits, and evidence documentation.	✓ Yes	Not assessed		—
A.5.32	Intellectual property rights	This control ensures intellectual property rights are protected through appropriate information security measures. Measures include access restrictions, encryption, and legal agreements.	✓ Yes	Not assessed		—
A.5.33	Protection of records	This control ensures records are securely stored and protected to prevent loss or unauthorized access. Measures include retention policies, secure storage, and access controls.	✓ Yes	Not assessed		—
A.5.34	Privacy and protection of PII	This control protects privacy and ensures the secure handling of personally identifiable information (PII). Measures include anonymization, encryption, and compliance with privacy laws.	✓ Yes	Not assessed		—
A.5.35	Independent review of information security	This control ensures independent reviews of information security to evaluate effectiveness and compliance. Measures include external audits, risk assessments, and follow-up actions.	✓ Yes	Not assessed		—
A.5.36	Compliance with policies, rules and standards for information security	This control ensures compliance with all policies, rules, and standards for information security. Measures include regular training, policy reviews, and enforcement mechanisms.	✓ Yes	Not assessed		—
A.5.37	Documented operating procedures	This control develops and maintains documented operating procedures to ensure consistency in security practices. Measures include process documentation, version control, and accessibility.	✓ Yes	Not assessed		—
A.6.1	Screening	This control ensures the implementation of screening processes to verify the suitability of candidates before employment. Measures include background checks, identity verification, and assessment of ...	✓ Yes	Not assessed		—
A.6.2	Terms and conditions of employment	This control ensures that terms and conditions of employment include information security responsibilities. Measures include explicit clauses about confidentiality, compliance with policies, and cons...	✓ Yes	Not assessed		—
A.6.3	Information security awareness, education and training	This control ensures that employees receive regular information security awareness, education, and training. Measures include scheduled training sessions, e-learning programs, and simulated phishing ...	✓ Yes	Not assessed		—
A.6.4	Disciplinary process	This control establishes a disciplinary process to address breaches of information security policies. Measures include clear guidelines, escalation procedures, and consistent enforcement to maintain ...	✓ Yes	Not assessed		—
A.6.5	Responsibilities after termination or change of employment	This control ensures that responsibilities related to information security are defined and enforced after termination or role changes. Measures include revoking access rights, collecting organization...	✓ Yes	Not assessed		—
A.6.6	Confidentiality or non-disclosure agreements	This control implements confidentiality or non-disclosure agreements to protect sensitive information. Measures include signed agreements at the start of employment, periodic reminders, and enforceme...	✓ Yes	Not assessed		—
A.6.7	Remote working	This control ensures the secure management of information security risks during remote working. Measures include secure access to corporate systems, mandatory use of VPNs, and policies for handling s...	✓ Yes	Not assessed		—
A.6.8	Information security event reporting	This control ensures employees can promptly report information security events. Measures include incident reporting channels, awareness campaigns, and follow-up procedures to investigate and address ...	✓ Yes	Not assessed		—
A.7.1	Physical security perimeters	This control establishes physical security perimeters to protect critical areas from unauthorized access. Measures include access barriers, access controls, and monitoring systems to ensure only authorized ...	✓ Yes	Not assessed		—
A.7.2	Physical entry	This control ensures physical entry points are controlled and monitored to prevent unauthorized access. Measures include badge systems, security personnel, and visitor logs.	✓ Yes	Not assessed		—
A.7.3	Securing offices, rooms and facilities	This control ensures that offices, rooms, and facilities are secured to protect information and resources. Measures include locked doors, restricted areas, and surveillance systems.	✓ Yes	Not assessed		—
A.7.4	Physical security monitoring	This control implements physical security monitoring to detect and respond promptly to threats. Measures include CCTV systems, motion detectors, and real-time alerts.	✓ Yes	Not assessed		—
A.7.5	Protecting against physical and environmental threats	This control protects systems and resources from physical and environmental threats. Measures include fire suppression systems, temperature controls, and flood prevention barriers.	✓ Yes	Not assessed		—
A.7.6	Working In secure areas	This control ensures that secure areas are managed to allow authorized access only. Measures include access control systems, visitor escorts, and activity monitoring.	✓ Yes	Not assessed		—
A.7.7	Clear desk and clear screen	This control ensures sensitive information is not left exposed by adopting clear desk and clear screen policies. Measures include locking sensitive documents away and auto-locking screens when not in...	✓ Yes	Not assessed		—
A.7.8	Equipment siting and protection	This control ensures that equipment is positioned and protected to prevent unauthorized access or damage. Measures include secure mounting, locked cabinets, and restricted access areas.	✓ Yes	Not assessed		—
A.7.9	Security of assets off-premises	This control ensures assets used or stored off-premises are secured to maintain confidentiality and integrity. Measures include encryption, secure transport, and access tracking.	✓ Yes	Not assessed		—
A.7.10	Storage media	This control safeguards storage media to prevent unauthorized access or tampering. Measures include secure storage, encryption, and access restrictions.	✓ Yes	Not assessed		—
A.7.11	Supporting utilities	This control ensures that supporting utilities, such as power and cooling systems, are reliable and protected from disruptions. Measures include redundant systems and physical security.	✓ Yes	Not assessed		—
A.7.12	Cabling security		✓ Yes	Not assessed		—

Ref	Control / Requirement	Description	Applicable?	Result	Justification	Applied Controls
		This control ensures that cables are secured to prevent unauthorized interception or damage. Measures include protective conduits, proper labeling, and secure routing.				
A.7.13	Equipment maintenance	This control ensures that equipment is maintained to guarantee proper functioning and prevent failures. Measures include regular servicing, secure maintenance practices, and authorized personnel acce...	✓ Yes	Not assessed		—
A.7.14	Secure disposal or re-use of equipment	This control ensures the secure disposal or reuse of equipment to protect sensitive information. Measures include data sanitization, physical destruction, and certified disposal processes.	✓ Yes	Not assessed		—
A.8.1	User end point devices	This control ensures the protection of endpoint devices such as laptops, desktops, and mobile devices by implementing security measures like endpoint detection, encryption, and secure configurations ...	✓ Yes	Not assessed		—
A.8.2	Privileged access rights	This control ensures that privileged access rights are granted, managed, and monitored carefully to prevent misuse and enhance security. Measures include role-based access controls, periodic reviews,...	✓ Yes	Not assessed		—
A.8.3	Information access restriction	This control restricts access to sensitive information based on need-to-know principles. Measures include user authentication, role-based permissions, and regular access reviews.	✓ Yes	Not assessed		—
A.8.4	Access to source code	This control secures access to source code by preventing unauthorized viewing, modification, or exposure. Measures include version control, secure repositories, and restricted developer access.	✓ Yes	Not assessed		—
A.8.5	Secure authentication	This control implements strong authentication mechanisms, such as multi-factor authentication, to verify user identities and prevent unauthorized access.	✓ Yes	Not assessed		—
A.8.6	Capacity management	This control ensures system capacity is managed to provide adequate performance and prevent disruptions. Measures include monitoring resource usage and planning for future needs.	✓ Yes	Not assessed		—
A.8.7	Protection against malware	This control deploys measures like antivirus software, threat detection tools, and regular updates to protect systems from malware and malicious attacks.	✓ Yes	Not assessed		—
A.8.8	Management of technical vulnerabilities	This control identifies, evaluates, and remediates technical vulnerabilities promptly to minimize security risks. Measures include vulnerability scanning and patch management.	✓ Yes	Not assessed		—
A.8.9	Configuration management	This control ensures consistent management of system configurations to maintain security settings and prevent unauthorized changes.	✓ Yes	Not assessed		—
A.8.10	Information deletion	This control ensures sensitive information is securely deleted when no longer required to prevent unauthorized recovery or exposure.	✓ Yes	Not assessed		—
A.8.11	Data masking	This control protects sensitive information during processing or display by using data masking techniques to obscure data from unauthorized users.	✓ Yes	Not assessed		—
A.8.12	Data leakage prevention	This control implements mechanisms to prevent the accidental exposure of sensitive data through email, removable media, or other channels.	✓ Yes	Not assessed		—
A.8.13	Information backup	This control ensures critical information is backed up regularly and securely to ensure its availability in case of incidents or disasters.	✓ Yes	Not assessed		—
A.8.14	Redundancy of information processing facilities	This control ensures redundancy is built into processing facilities to maintain availability and operations during system failures or emergencies.	✓ Yes	Not assessed		—
A.8.15	Logging	This control enables logging of activities within systems to support monitoring, incident detection, and forensic investigations.	✓ Yes	Not assessed		—
A.8.16	Monitoring activities	This control ensures the ongoing monitoring of system activities to detect, respond to, and mitigate security threats.	✓ Yes	Not assessed		—
A.8.17	Clock synchronization	This control ensures system clocks are synchronized to maintain accurate and consistent timestamps for logs and other critical processes.	✓ Yes	Not assessed		—
A.8.18	Use of privileged utility programs	This control restricts and monitors the use of privileged utility programs to prevent misuse and unauthorized actions.	✓ Yes	Not assessed		—
A.8.19	Installation of software on operational systems	This control ensures software installation on operational systems is managed securely to prevent vulnerabilities or unauthorized changes.	✓ Yes	Not assessed		—
A.8.20	Networks security	This control ensures network security through firewalls, intrusion detection systems, and access controls to protect against unauthorized access and attacks.	✓ Yes	Not assessed		—
A.8.21	Security of network services	This control ensures network services are protected to maintain confidentiality, integrity, and availability during use.	✓ Yes	Not assessed		—
A.8.22	Segregation of networks	This control implements network segregation to limit the spread of threats and minimize the impact of potential breaches.	✓ Yes	Not assessed		—
A.8.23	Web filtering	This control uses web filtering tools to block unauthorized or harmful content from being accessed over the internet.	✓ Yes	Not assessed		—
A.8.24	Use of cryptography	This control ensures cryptographic techniques are applied to protect data confidentiality, integrity, and authenticity.	✓ Yes	Not assessed		—
A.8.25	Secure development life cycle	This control integrates security into all stages of the development life cycle to ensure systems and applications are built securely.	✓ Yes	Not assessed		—
A.8.26	Application security requirements	This control defines and enforces security requirements for applications to safeguard against vulnerabilities.	✓ Yes	Not assessed		—
A.8.27	Secure system architecture and engineering principles	This control ensures secure design principles are adopted during the development of system architectures.	✓ Yes	Not assessed		—
A.8.28	Secure coding	This control implements secure coding practices to minimize vulnerabilities in developed software.	✓ Yes	Not assessed		—
A.8.29	Security testing in development and acceptance	This control ensures security testing is conducted during development and acceptance phases to identify weaknesses.	✓ Yes	Not assessed		—
A.8.30	Outsourced development	This control ensures security risks are managed effectively when development is outsourced to third-party vendors.	✓ Yes	Not assessed		—
A.8.31	Separation of development, test and production environments	This control ensures development, test, and production environments are segregated to prevent unintended interactions and unauthorized access.	✓ Yes	Not assessed		—
A.8.32	Change management	This control ensures changes to systems are managed securely to minimize risks and maintain operational stability.	✓ Yes	Not assessed		—

Ref	Control / Requirement	Description	Applicable?	Result	Justification	Applied Controls
A.8.33	Test information	This control protects test data to prevent the exposure of sensitive or confidential information during testing processes.	✓ Yes	Not assessed		—
A.8.34	Protection of information systems during audit testing	This control ensures that systems and data are safeguarded during audits by preventing unauthorized access, data leakage, or disruptions. Measures include using non-production environments, access re...	✓ Yes	Not assessed		—